

腾讯安全 | 云鼎实验室

锋刃无影 御见未来

腾讯安全沙龙第3期（成都站）



IFS

关于我

About me

某不知名公司的安全研究员
胡雪松

主要方向是Android逆向、Harmony逆向、pwn、kernel、免杀、渗透
擅长代码分析，算法逆向，移动加固对抗等

<https://github.com/u33pk>

议题名称：鸿蒙安全研究与逆向分析

一、关于鸿蒙

问1：鸿蒙是自研么

答：鸿蒙从openHarmony来看，字节码、虚拟机均有别于Android。
鸿蒙5之前的版本为基于Android的版本。

问2：鸿蒙的运营策略

答：就目前来看，鸿蒙运营逻辑更接近IOS，不能随意安装hap、app，分发测试版本需要开发者授权等

问3：鸿蒙的开发

答：目前的主流开发为使用arkTs和C++混合开发，开发模式类似于Android
arkTs是TypeScript的超集，可以无缝使用nodejs生态。
C++的部分与Android类似，都是提供了原生结构供C++访问

二、鸿蒙安全研究的目的

1. 构建强大的安全机制，防止恶意软件、黑客攻击、数据泄露等问题
2. 发现并修补潜在漏洞，提升系统的抗攻击能力和稳定性
3. 为开发者提供更安全的开发环境，降低应用被攻击的风险
4. 鸿蒙系统的分布式架构和微内核设计为其安全研究提供了独特的技术背景
5. 针对鸿蒙系统的安全研究尚处于起步阶段。深入研究可以填补这一领域的空白，为后续的安全实践提供理论基础和技术支持

三、鸿蒙抓包

app抓包是分析app最基础的事情。

与苹果直接装证书就能用不同，也与Android不root就装不了证书不同

如果app不做限制，直接装上证书也能用，但是此时很多系统app是不支持正常解析流量的。

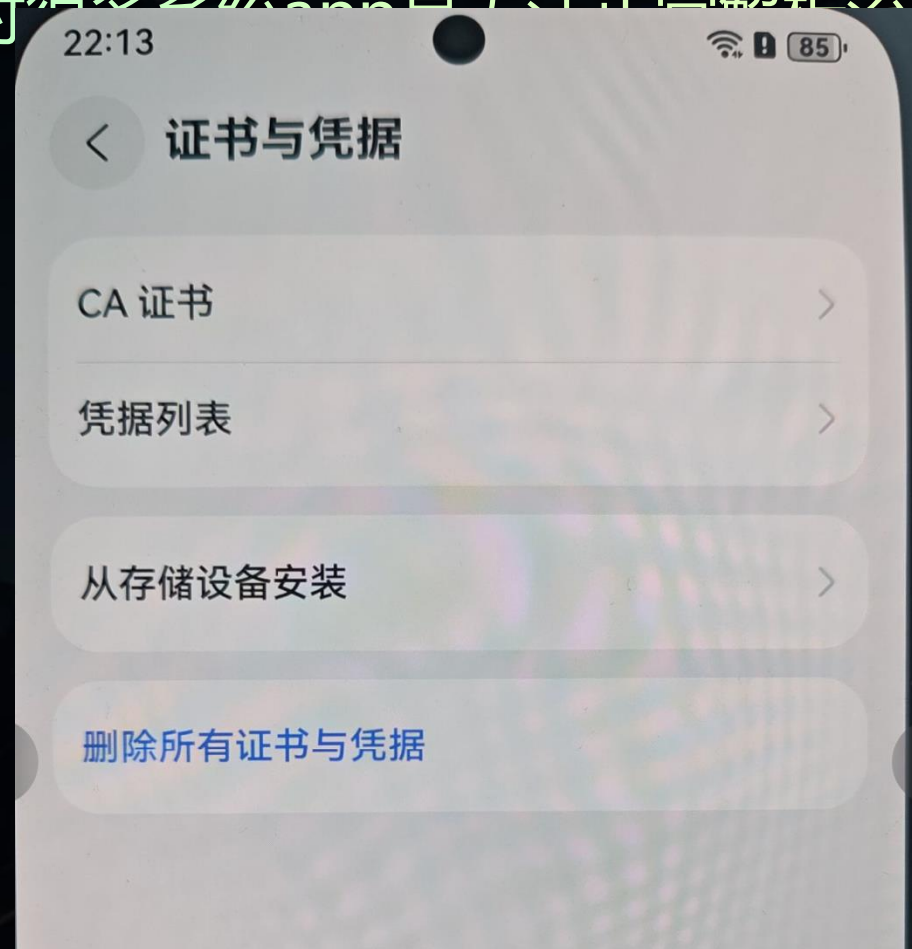
所以要装系统证书还是需要root。

先说最基础的，也是最常用的安装证书+抓包

设置->安全->更多安全设置->加密和凭证

选择“从存储设备安装”

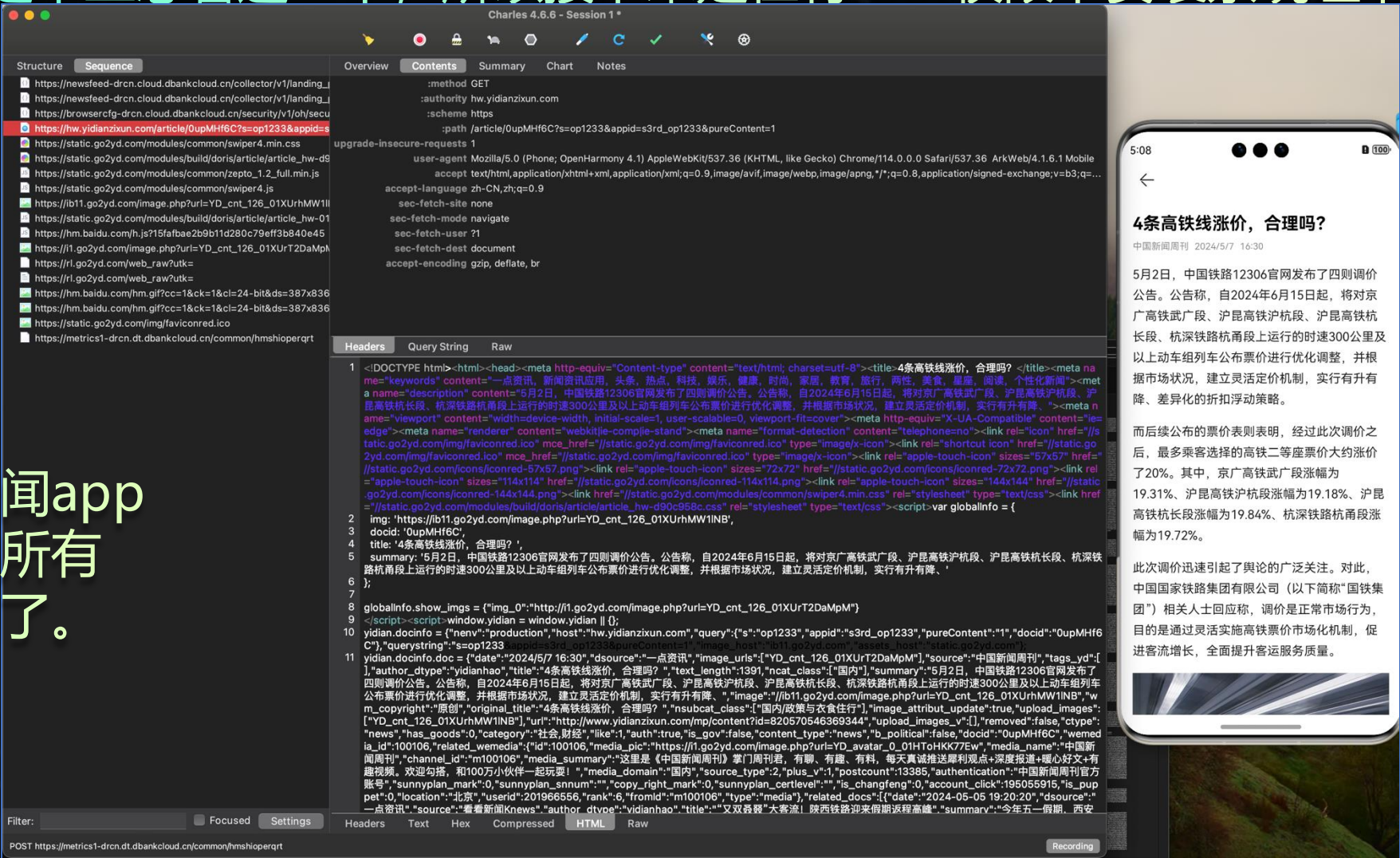
点击pem证书即可。



三、鸿蒙抓包

但是我知道各位肯定不止想看这一个，所以接下来是在有root权限下安装系统证书，先来看效果：

这是模拟器内置的新闻app
这样的话，系统几乎所有
流量都可以直接看到了。



三、鸿蒙抓包

可以尝试和Android
不一定生效，还有
研究中发现，有一
会生效。

中方案并
生去，才

```
-----BEGIN CERTIFICATE-----
CHARLES Root R1
=====
-----BEGIN CERTIFICATE-----
MIIFVjCCBD6gAwIBAgIGAY6XMvxPMA0GCSqGSIb3DQEBCwUAMIGvMUAwPgYDVQQDDDDdDaGFyYbGVz
IFByb3h5IENBICgxIEFwciAyMDI0LCBxZW50b20vc3NsMREwDwYDVQQKDAhYSzcyIEEx0ZDERMA8GA1UE
DBxodHRwczovL2NoYXJsZXNwcm94eS5jb20vc3NsMREwDwYDVQQKDAhYSzcyIEEx0ZDERMA8GA1UE
BwwIQXVja2xhbmQxETAPBgNVBAGMCEF1Y2tsYW5kMQswCQYDVQQGEwJOWjAeFw0yNDAzMzEwMTA4
MDRaFw0yNDAzMzEwMTA4MDRaMIGvMUAwPgYDVQQDDDDdDaGFyYbGVzIFByb3h5IENBICgxIEFwciAy
MDI0LCBxZW50b20vc3NsMREwDwYDVQQKDAhYSzcyIEEx0ZDERMA8GA1UEBwwIQXVja2xhbmQxETAPBgNV
cm94eS5jb20vc3NsMREwDwYDVQQKDAhYSzcyIEEx0ZDERMA8GA1UEBwwIQXVja2xhbmQxETAPBgNV
BAGMCEF1Y2tsYW5kMQswCQYDVQQGEwJOWjAeFw0yNDAzMzEwMTA4MDRaFw0yNDAzMzEwMTA4MDRa
ALFeztUaFBDX1+4fS00ihlZ6m12j21BFQUDJh6x6HAF+D/rNntQaICsWak3W5yiARvzSYS7Rlz40
dRuTrYzC7zpn1sr2ZVqQdrVqIMYgYNxVAXk+iSmkTK6WUNGRf0JR7eaU1HPYi4fWRTcnsfAC6yYT
N8hXzVn+1VNaU6v0dgaFt2k+96uZNDY5NzncIDrjETnzS+v5pjuixtCDeuwhwj0z64i3XQhMHCS4
CtzxZTApYIZw+nUHPTLr+htYbUgp40rIQHd7XgVyi1h+fi295YrSkoCc6CHELSshIC5gS0ttT8jk
ab5WQOTQ15K0y/qG9r8uZsMQiAw3EgDzRFgLBjUCAwEAAOCAXQwggFwMA8GA1UdEwEB/wQFMAMB
Af8wggEsBg1ghkgBhvCAQ0EggEdE4IBGVROaXMGUm9vdCBjZjZ0aWZpY2F0ZSB3YXMGZ2VhZjZ0
dGVkIGJ5IENoYXJsZXNwcm94eS5jb20vc3NsMREwDwYDVQQKDAhYSzcyIEEx0ZDERMA8GA1UE
ZSBpcyBwYXJ0IG9mIGEGY2VydGlmYW50b20vc3NsMREwDwYDVQQKDAhYSzcyIEEx0ZDERMA8GA1UE
YnJvd3NpbmMgdGhyb3VnaCBDaGFyYbGVzIFByb3h5IENBICgxIEFwciAyMDI0LCBxZW50b20vc3Ns
Zm9yIHRoaXMGd2Vic2l0ZS4gUGx1YXNlIHNLZSBodHRwOi8vY2h5cmxlc3Byb3h5LmNvbS9zc2wg
Zm9yIG1vcmUgaW5mb3JtYXRpb24uMA4GA1UdDwEB/wQEAwICBDAdBgNVHQ4EFgQU1Jfd9dMazmz/
kGwSaK6Xgyhnr/cwDQYJKoZIhvcNAQELBQADggEBAJVSz0xq6nG/DSEuWDuAtJjK30nvQDUJtWwH
tghKU5MnAUbvUxniQI//bTgwuLXdv/ZzvNnmUYetiz9c95yNiJpaGillHHYKuZ/PF/sxKAuXTvzP
LDULM+9mGFV6eZf+xUFJ+HTLkmROJRNGEk7RwvFnhb9KB7RBYon7BskFSgnr192QoaFVxKPRW6ba
4Yf9hkhuGldisMRIGK5e0q+hu7Z1cDtPsPXGAI7WPgNUVHPLr0AKZ5nAMrJEzBc0jmPnBZ+296o
LBp90VSmlIvhmNZr/AjXbjuas+TTxZuQ3nTocDo0WEIMeds4Tr1jkGqxdauPuLDC7T2S7y0Avk7K
itA=
-----END CERTIFICATE-----
```


四、鸿蒙模拟器root

对于研究操作系统和app来说，root很重要。很多时候没有root，寸步难行

目前鸿蒙真机的root，我这里并没有进展，但是模拟器还是有一些的。

在github上有一个项目是通过修改qemu的img镜像来完成root的，但是这个方案自从更新了DevEco-Studio之后就已经失效了。

原理很简单，在emulator二进制中增加了对镜像签名的校验。

```
qword_1096722F8 = QString::fromAscii_helper((QString *)"Image", (const char *)5, v17);
__cxa_atexit((void (__fastcall *)(void *))QString::~QString, &qword_1096722F8, (void *)&_mh_execute_header);
qword_109672300 = QString::fromAscii_helper((QString *)"image_signature/Image.hwp7s", (const char *)0x1B, v18);
__cxa_atexit((void (__fastcall *)(void *))QString::~QString, &qword_109672300, (void *)&_mh_execute_header);
qword_109672308 = QString::fromAscii_helper((QString *)"image_signature/system.img.hwp7s", (const char *)0x20, v19);
__cxa_atexit((void (__fastcall *)(void *))QString::~QString, &qword_109672308, (void *)&_mh_execute_header);
qword_109672310 = QString::fromAscii_helper((QString *)"image_signature/vendor.img.hwp7s", (const char *)0x20, v20);
__cxa_atexit((void (__fastcall *)(void *))QString::~QString, &qword_109672310, (void *)&_mh_execute_header);
qword_109672318 = QString::fromAscii_helper((QString *)"image_signature/userdata.img.hwp7s", (const char *)0x22, v21);
__cxa_atexit((void (__fastcall *)(void *))QString::~QString, &qword_109672318, (void *)&_mh_execute_header);
qword_109672320 = QString::fromAscii_helper((QString *)"image_signature/sys_prod.img.hwp7s", (const char *)0x22, v22);
__cxa_atexit((void (__fastcall *)(void *))QString::~QString, &qword_109672320, (void *)&_mh_execute_header);
qword_109672328 = QString::fromAscii_helper((QString *)"image_signature/ramdisk.img.hwp7s", (const char *)0x21, v23);
return __cxa_atexit((void (__fastcall *)(void *))QString::~QString, &qword_109672328, (void *)&_mh_execute_header);
}
```

四、鸿蒙模拟器root

有了这个思路，其实就可以想办法绕过了
我在这里提供如下几个思路：

- 1. 直接aptch emulator二进制，缺点：校验处不止这一个地方。
- 2. 使用旧版emu
- 3. 依旧使用旧版
- 4. 有没有什么办

我言尽于此，以

```
→ H hdc shell
$ id
uid=2000(shell) gid=2000(shell) groups=2000(shell),1006(file_manager),1007(log),1008(user_data_rw),1097(netsys_socket),3009(readproc)
context=u:r:sh:s0
$ su
# id
uid=0(root) gid=0(root) groups=0(root),1006(file_manager),1007(log),1008(user_data_rw),1097(netsys_socket),3009(readproc) context=u:r:
sh:s0
# uname -a
Linux localhost 5.10.209 #1 SMP Sat Oct 5 17:18:13 CST 2024 aarch64
#
```



五、鸿蒙注入与hook

由于实体机我们并没有root权限，所以此处讲解的均为模拟器方案
从刚才的图中已经看到，模拟器的内核是一个linux-5.10.209的内核，
所以我们这里尝试直接按照linux的注入与hook方案来做

1. 我们要选择一个合适的hook框架来移植
2. 我们要选择一个合适的注入方案

没有选择frida的理由：

1. frida适配非常复杂
2. frida的musl支持非常差
3. frida没有对ark虚拟机有支持，所以在与其他hook方案的对比中没有太大优势。

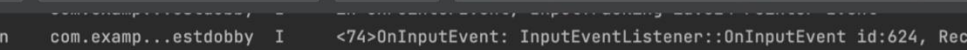
五、鸿蒙注入与hook

我们先看一个效果：

```
#define LOG_PRINT_DOMAIN 0xFF00
#define APP_LOG_DOMAIN 0x0001
constexpr const char *APP_LOG_TAG = "orz";
#define HELLO_LOGI(...) ((void)OH_LOG_Print(LOG_APP, LOG_INFO, LOG_DOMAIN, APP_LOG_TAG, __VA_ARGS__))
#define HELLO_LOGD(...) ((void)OH_LOG_Print(LOG_APP, LOG_DEBUG, LOG_DOMAIN, APP_LOG_TAG, __VA_ARGS__))
#define HELLO_LOGW(...) ((void)OH_LOG_Print(LOG_APP, LOG_WARN, LOG_DOMAIN, APP_LOG_TAG, __VA_ARGS__))
#define HELLO_LOGE(...) ((void)OH_LOG_Print(LOG_APP, LOG_ERROR, LOG_DOMAIN, APP_LOG_TAG, __VA_ARGS__))

install_hook_name(Add_self, napi_value, napi_env env, napi_callback_info info) {
    HELLO_LOGI("hook Add function");
    napi_value sum;
    napi_create_double(env, 103, &sum);
    return sum;
    // return orig_Add_self(env, info);
}

static napi_value Add_self(napi_env env, napi_callback_info info) {
    size_t requireArgc = 2;
    // hook name()
```



The screenshot shows the Android Studio interface with the Logcat window open. The Logcat displays various system logs, including a red box highlighting the text "hook Add function" and "Test NAPI 2 + 3 = 103". The Logcat also shows other logs related to the application, such as "TransferStation", "SessionImpl", "SessionImpl", "Tracking", "Tracking", "ure", "ure", "adSkeleton", and "IPCThreadSkeleton".

```

/system/bin/toybox
/system/bin/toybox
/system/bin/toybox
/system/bin/toybox

```

```
[heap]
[heap]
/data/local/tmp/libevil-musl.so
/data/local/tmp/libevil-musl.so
/data/local/tmp/libevil-musl.so
```

```
/system/lib64/platformsdk/libfmark_client.z.so
```

```
/dev/zero (deleted)
```

```
/dev/___parameters___/param_storage
```

五、鸿蒙注入与hook

可以看到我们已经成功把libevil-musl.so注入进去了并且已经成功在native层把2+3的返回值hook掉了

这只是一个简单的demo，只能说明是可行的，并不具备实际价值。如果后续需要增加更多支持，比如对ark虚拟机hook的支持，还需要做更多的适配工作才行。

另外需要说明的是，鸿蒙手机上的内核在执行uname之后，显示的不再是linux了，而是“hongmeng Kernel”，所以这一套方案在真机上是否有效，还有待验证。

```
→ ~ hdc shell
$ uname -a
HarmonyOS localhost HongMeng Kernel 1.9.3 #1 SMP Thu Mar 13 09:31:56 UTC 2025 aarch64
$
$
$
```

六、鸿蒙app重打包

app重打包，这事其实分为三个步骤

1. hap拆包
2. hap打包
3. hap签名

前两步其实都有官方的工具可以使用

在SDK中有一个工具叫 “app_unpacking_tool.jar” 和 “app_packing_tool.jar”

这两个工具就是官方用来打包和解包的工具

我在这里放一个命令格式：

```
java -jar app_unpacking_tool.jar --mode hap --hap-path <path> --out-path  
<path> [--force true]
```

更多的详情可以查看官方文档：

<https://gitcode.com/openharmony/docs/blob/master/zh-cn/application-dev/tools/unpacking-tool.md>

六、鸿蒙app重打包

有了这两步之后，我们为了安装到模拟器或者手机上，就需要签名了。当然有的app即便不签名，也可以安装在模拟器上，此处不说这种情况。签名，需要注意的是，和Android APP 签名流程不一样，并不是说拿着自己申请的证书签就行了。这里面有几个点需要注意一下：

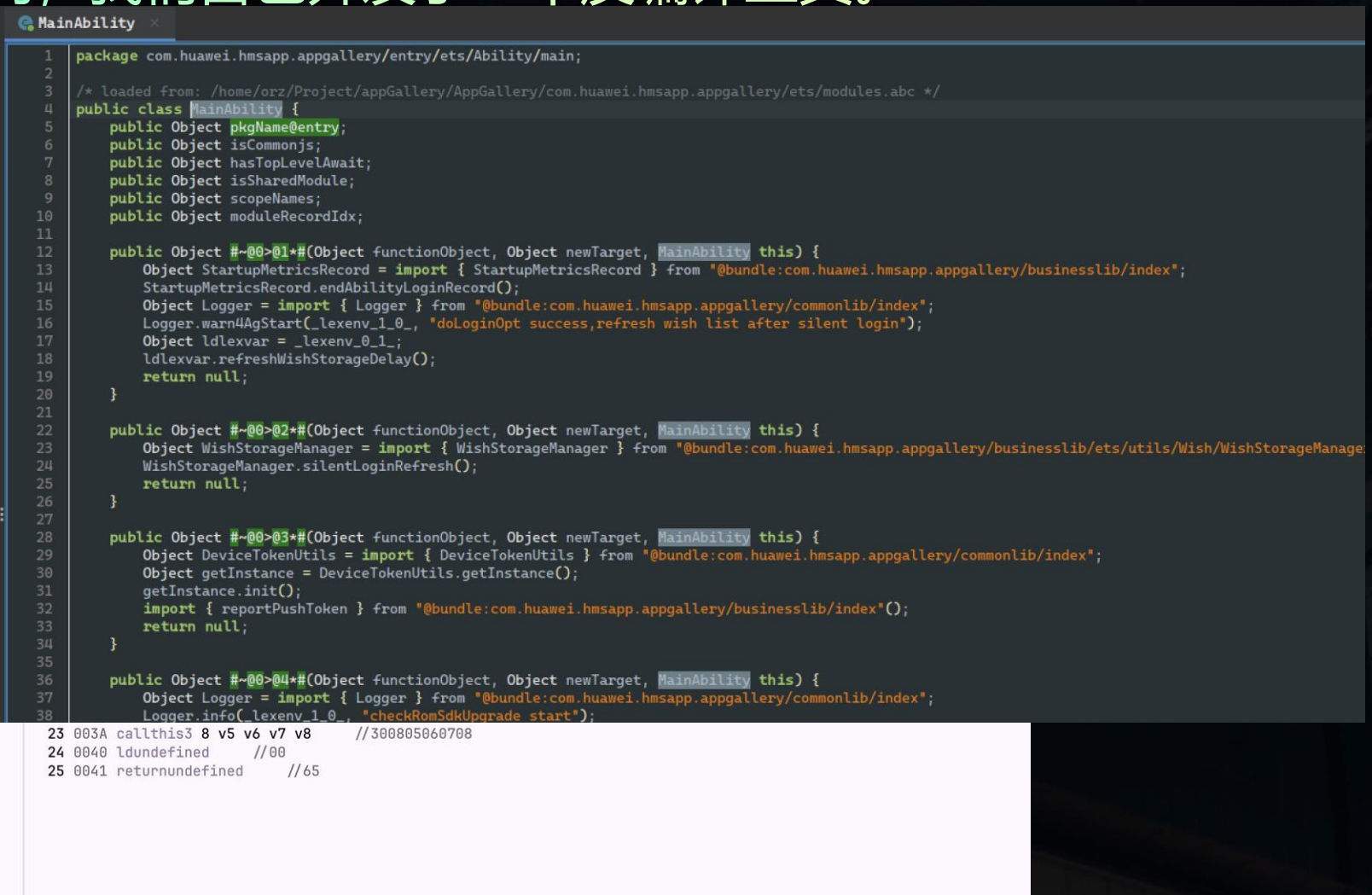
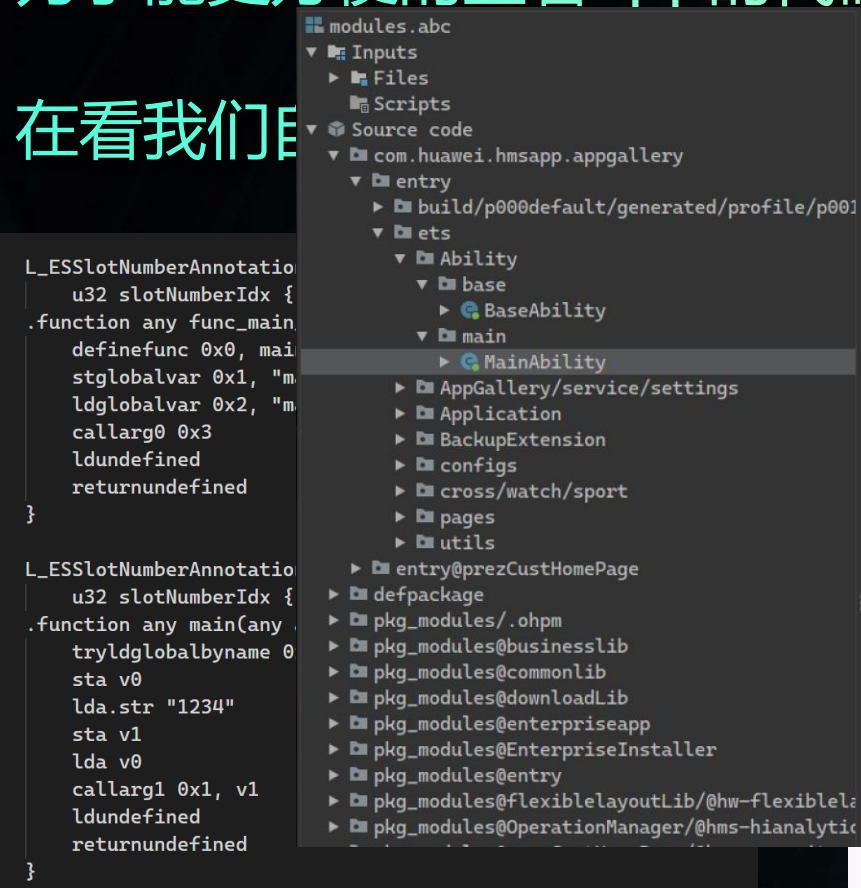
1. 包名要相同
2. 权限要相同
3. 签名命令在DevEco-Studio工具的代码中，可以自行寻找

此处我就不再展开了。

七、鸿蒙app反编译

为了能更方便的查看app的代码，我们自己开发了一个反编译工具。

在看我们的



七、鸿蒙app反编译

111.hap

/tmp/hapSpace/test/111/ets/modules.abc

@ohos.app

@ohos.curves

@ohos.matrix4

@system.app

@system.curves

@system.matrix4

@system.router

_ESConcurrentModuleRequestsAnnotation

_ESSlotNumberAnnotation

entry

ets

backupExtension

backupTransfer

DbTransferManager

fields

methods

querySourceCount

func_main_0

transfer

querySourceForPage

batchInsertToTarget

initTargetDb

moveDbFile

initSourceDb

DbTransferManager

#1239828885240203759#

FileTransferManager

SpTransferManager

common

components

entryability

model

代码查看

CFG结构

<>汇编代码

Q 搜索结果

111.hap

/tmp/hapSpace/test/111/ets/modules.abc

@ohos.app

@ohos.curves

@ohos.matrix4

@system.app

@system.curves

@system.matrix4

@system.router

_ESConcurrentModuleRequestsAnnotation

_ESSlotNumberAnnotation

entry

ets

backupExtension

backupTransfer

DbTransferManager

fields

methods

querySourceCount

func_main_0

transfer

querySourceForPage

batchInsertToTarget

initTargetDb

moveDbFile

initSourceDb

DbTransferManager

#1239828885240203759#

汇编代码展示

AsmPath:

lable_0

0 mov v0 FunctionObject

2 mov v1 NewTarget #

5 mov v2 this # v2 =

8 mov v3 arg0 # v3 =

11 mov v4 arg1 # v4 =

14 asyncfunctionenter

15 sta v7 # v7 = acc

17 ldai 0 # acc = 0

22 sta v6 # v6 = acc

24 ldundefined # acc

25 sta v5 # v5 = acc

27 ldundefined # acc

28 sta v8 # v8 = acc

30 lda v2 # acc = v2

32 sta v12 # v12 = a

34 lda v12 # acc = v

36 ldobjbyname 0 "ini

40 sta v11 # v11 = a

42 lda v3 # acc = v3

44 sta v13 # v13 = a

46 lda v11 # acc = v

48 callthis1 2 v12 v1

52 asyncfunctionawait

54 suspendgenerator v

56 lda v7 # acc = v7

58 resumegenerator #

59 sta v12 # v12 = a

61 lda v7 # acc = v7

63 getresumemode # a

64 sta v11 # v11 = a

66 ldai 1 # acc = 1

71 eq 4 v11 # acc =

74 jeqz 6 # if (acc :

lable_76

76 lda v12 # acc = v12

78 throw # throw acc

lable_80

代码查看

CFG结构

<>汇编代码

Q 搜索结果

FileTransferManager ×

BackupExtension ×

checkPermissions ×

grantPermission ×

querySourceCount ×

语言: javascript 主题: rosePineDawn 禁用编辑: 自动聚焦: indentWithTab: tabSize: 2

1

2 async function querySourceCount(FunctionObject, NewTarget, thisValue, arg0, arg1) {

3 let initSourceDb = thisValue.initSourceDb;

4 let result = await initSourceDb(arg0);

5 if (result !== true) throw result;

6

7 let condition = 5 !== undefined;

8 if (condition) {

9 condition = 6 !== undefined;

10 if (condition) {

11 result.close();

12 return undefined;

13 }

14 }

15

16 let preds = (await import("@ohos:data.relationalStore")).default.RdbPredicates;

17 let rdbPredicates = new preds(arg1);

18 let sourceRdbStore = thisValue.sourceRdbStore;

19

20 let queryResult = await sourceRdbStore.query(rdbPredicates, ["count(1)"]);

21 if (queryResult !== true) throw queryResult;

22

23 let firstRow = await queryResult.goToFirstRow();

24 if (firstRow !== true) {

25 queryResult.close();

26 return undefined;

27 }

28

29 let count = await queryResult.getLong(0);

30 queryResult.close();

31 return count;

32 }

33 }

七、鸿蒙app反编译

111.hap

/tmp/hapSpace/test/111/ets/modules.abc

@ohos.app
@ohos.curves
@ohos.matrix4
@system.app
@system.curves
@system.matrix4
@system.router
_ESConcurrentModuleRequestsAnnotation
_ESSlotNumberAnnotation

entry

ets

backupExtension

backupTransfer

DbTransferManager

fields

methods

querySourceCount
func_main_0
transfer
querySourceForPage
batchInsertToTarget
initTargetDb
moveDbFile
initSourceDb
DbTransferManager
#12398288885240203759#

FileManagerer
SpTransferManager

common

components

entryability

model

pages

代码查看

CFG结构

<>汇编代码

搜索结果

225: asynctransferwaituntilv7 # await AwaitExpression(v7, acc)
227: suspendgenerator v7 # acc = v7GeneratorSuspend(acc)
229: ldr v7 # acc = v7
231: resumeGenerator # acc = accGeneratorResume()
232: str v12 # v12 = acc
234: ldr v7 # acc = v7
236: generateumode # acc = accTYPE
237: str v11 # v11 = acc
239: ldr r # acc = 1
241: eq 24 v11 # acc = v11 != acc
243: jmp 8 # if (acc == 0) GOTO label_253

249: ldr v12 #
251: throw # 0

190: jmp 5 # GOTO label_200
191: undefined # acc = UNDEFINED
192: strictfp 19 v12 # acc = 19 ldr v12
193: jmp 4 # if (acc == 0) GOTO label_197

197: undefined # acc = UNDEFINED
198: jmp 27 # GOTO label_225

创建项目

加载项目

上传Hap

Hap反编译

Js全部反编译

搜索

删除

设置

帮助

代码查看

CFG结构

<>汇编代码

搜索结果

111.hap

/tmp/hapSpace/test/111/ets/modules.abc

@ohos.app
@ohos.curves
@ohos.matrix4
@system.app
@system.curves
@system.matrix4
@system.router
_ESConcurrentModuleRequestsAnnotation
_ESSlotNumberAnnotation

entry

ets

backupExtension

backupTransfer

DbTransferManager

fields

methods

querySourceCount
func_main_0
transfer
querySourceForPage
batchInsertToTarget
initTargetDb
moveDbFile
initSourceDb
DbTransferManager
#12398288885240203759#

FileManagerer
SpTransferManager

common

components

entryability

model

pages

操作

结果

跳转反编译

com.qihoo.hms.browser/entry/ets/components/**scan**/Custom**Scan**/#15216546550740602509#

跳转反编译

com.qihoo.hms.browser/entry/ets/components/index/**scan**Button/func_main_0

跳转反编译

com.qihoo.hms.browser/entry/ets/components/**scan**/custom**Scan**Default/view/**Scan**Title/#10996038591418067601#

跳转反编译

com.qihoo.hms.browser/entry/ets/pages/**Scan**/#3934991737455598629#paramsLambda

跳转反编译

com.qihoo.hms.browser/entry/ets/components/**scan**/Custom**Scan**/startCustom**Scan**

跳转反编译

com.qihoo.hms.browser/entry/ets/components/**scan**/Custom**Scan**/#3257809185818083563#

跳转反编译

com.qihoo.hms.browser/entry/ets/pages/**Scan**/**scan**Result

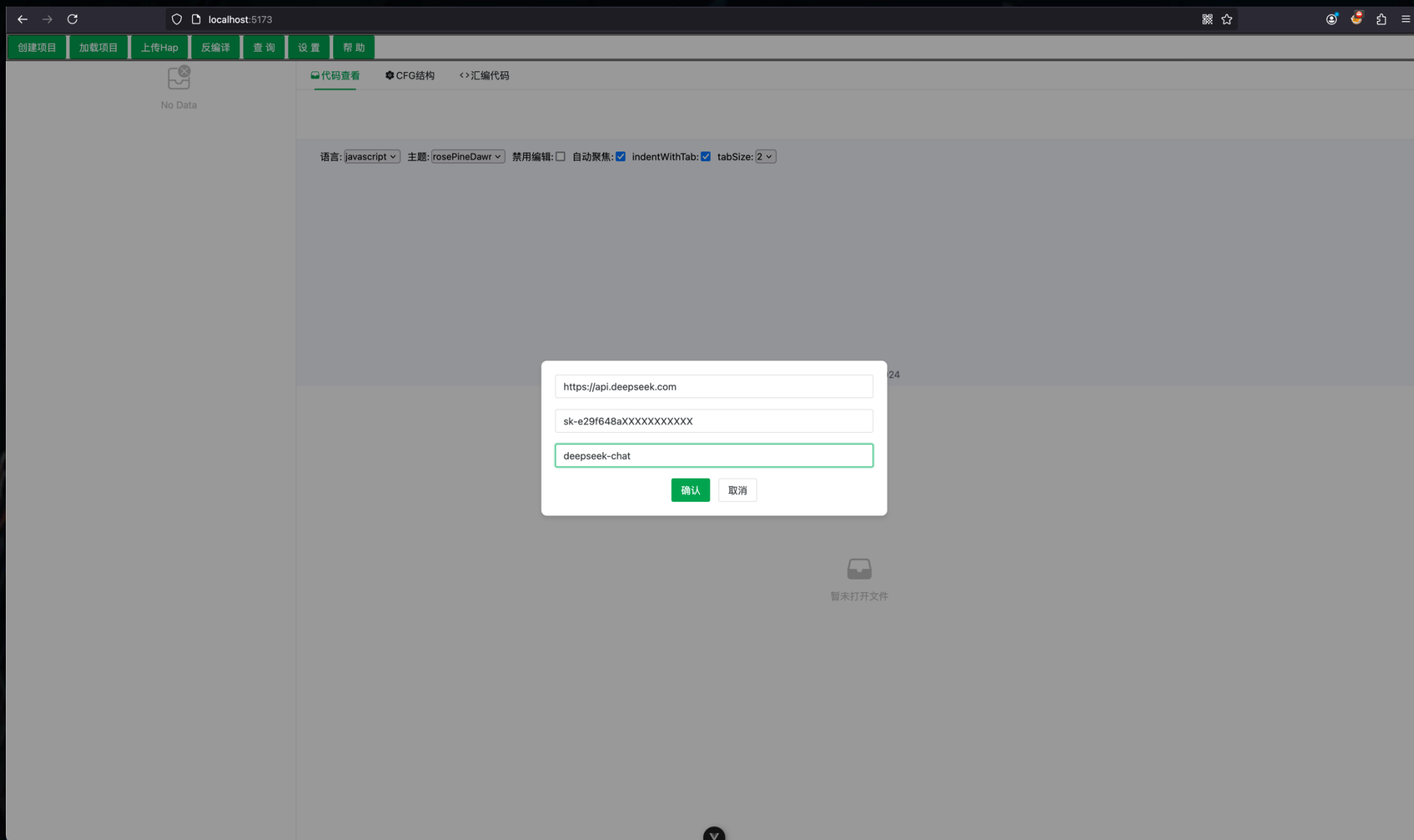
跳转反编译

com.qihoo.hms.browser/entry/ets/components/**scan**/custom**Scan**Default/view/**Scan**Title/updateStateVars

跳转反编译

com.qihoo.hms.browser/entry/ets/components/**scan**/Custom**Scan**/setWindowSize

七、鸿蒙app反编译



谢谢



IFS